ICAO

Doc 9303

机读旅行证件

第七版，2015 年

第 12 部分　机读旅行证件的公钥基础设施



经秘书长批准并由其授权出版

国际民用航空组织

ICAO

Doc 9303

机读旅行证件

第七版，2015 年

第 12 部分　机读旅行证件的公钥基础设施

经秘书长批准并由其授权出版

国际民用航空组织

国际民用航空组织分别以中文、阿拉伯文、英文、法文、俄文和西班牙文版本出版
999 Robert-Bourassa Boulevard, Montréal, Quebec, Canada H3C 5H7

下载文件和获取额外信息，请登录 www.icao.int/security/mrtd。

Doc 9303 号文件 — 《机读旅行证件》
第 12 部分 — 机读旅行证件的公钥基础设施
ISBN 978-92-9249-964-8

© ICAO 2016

保留所有权利。未经国际民用航空组织事先书面许可，不得将本出版物的任何部分复制、存储于检索系统或以任何形式或手段进行发送。

修订

《产品和服务目录》的补篇中公布了各项修订；在国际民航组织网站 www.icao.int 上有本目录及其补篇。以下篇幅供记录修订之用。

修订和更正记录

修订		
编号	日期	换页人

更正		
编号	日期	换页人

本出版物中所用称谓和陈述材料之方式，并不代表国际民航组织对任何国家、领土、城市或地区或其当局的法律地位，或就其边境或疆界的划分，表达了任何意见。

目 录

1. 范围…… 1

2. 公钥基础设施概述…… 1

3. 作用和责任…… 2

3.1 国家签名认证机构…… 3
3.2 证件签名者…… 3
3.3 查验系统…… 4
3.4 国家证书列表签名者…… 4
3.5 偏差列表签名者…… 4

4. 密钥管理…… 4

4.1 证件签名者密钥和证书…… 5
4.2 国家签名认证机构密钥和证书…… 6
4.3 证书撤销…… 7
4.4 加密算法…… 8

5. 分发机制…… 9

5.1 公钥目录分发机制…… 10
5.2 双边交换分发机制…… 11
5.3 国家证书列表分发机制…… 11

6. 公钥基础设施的信任和确认…… 12

6.1 信任锚的管理…… 13
6.2 证书/证书撤销列表确认和撤销检查…… 13

7. 证书和证书撤销列表概要…… 14

7.1 证书概要…… 15
7.2 证书撤销列表概要…… 22

8. 国家签名认证机构国家证书列表结构…… 25

8.1 SignedData 类型…… 25

8.2 ASN.1 国家证书列表规范…… 26

9. 参考材料（规范性）…… 27

第 12 部分附录 A 有效期（资料性）…… App A-1

A.1 示例 1…… App A-1
A.2 示例 2…… App A-1
A.3 示例 3…… App A-2

第 12 部分附录 B 证书和证书撤销列表概要参考文本（资料性）…… App B-1

第 12 部分附录 C 较早的证书概要（资料性） …… App C-1

第 12 部分附录 D RFC 5280 验证的兼容性（资料性）…… App D-1

D.1 与电子机读旅行证件相关的步骤…… App D-1
D.2 电子机读旅行证件不需要采取的步骤…… App D-5
D.3 为处理证书撤销列表需要做出的改动…… App D-6

1. 范围

Doc 9303 号文件第七版对国际民航组织关于机读旅行证件的规范进行了结构调整。在 Doc 9303 号文件的这一新版本中并未纳入对规范的大量修改，而是对内容进行了重新编排，形成一套关于 1 型机读官方旅行证件（TD1）、2 型机读官方旅行证件（TD2）和 3 型机读旅行证件（TD3）以及签证的规范。这套规范由多个不同文件组成，其中对一般规范（适用于所有机读旅行证件）以及与特定尺寸的机读旅行证件相关的规范做了分类。

Doc 9303 号文件第 12 部分是以 Doc 9303 号文件第 1 部分 —《机读护照》第六版第 2 卷 —《关于具有生物特征识别功能的电子护照的规范》（2006 年）和 Doc 9303 号文件第 3 部分 —《机读官方旅行证件》第三版第 2 卷 —《关于具有生物特征识别功能的电子机读旅行证件的规范》（2008 年）为基础编制的。

第 12 部分阐述了电子机读旅行证件应用的公钥基础设施（PKI）。其中对各签发国或签发机构的要求进行了规定，包括签发证书和证书撤销列表的认证机构（CA）的运行。还对接收国及其用于确认这些证书和证书撤销表的查验系统的要求进行了规定。

Doc 9303 号文件第 12 部分应结合下列文件进行阅读：

- Doc 9303 号文件第 10 部分 — 在非接触式集成电路（IC）中存储生物特征和其他数据的逻辑数据结构（LDS）；和
- Doc 9303 号文件第 11 部分 — 机读旅行证件的安全机制。

2. 公钥基础设施概述

电子机读旅行证件公钥基础设施（PKI）可以支持在电子机读旅行证件对象（包括证件安全对象（SO_D））上创建数字签名并随后对数字签名进行验证，以确保签署的数据是真实的且未被修改。证书被撤销、认证路径确认程序失败或电子签名验证失败本身并不能作为判断电子机读旅行证件无效的理由。这样的失败意味着无法通过电子手段验证逻辑数据结构数据的完整性和真实性，这时可以采用其他非电子机制来进行判断，并将其作为电子机读旅行证件整个查验工作的一部分。

电子机读旅行证件公钥基础设施比通用的多应用的公钥基础设施（如在[RFC 5280]中定义的因特网公钥基础设施）简单得多。在电子机读旅行证件公钥基础设施中，每一个签发国/签发机构都建立一个向终端实体（包括证件签名者）直接签发所有证书的单一认证机构（CA）。这些认证机构被称为国家签名认证机构（CSCAs）。在该基础设施中没有其他认证机构。接收国直接在每个签发国或签发机构的国家签名认证机构的密钥/证书里建立信任。

电子机读旅行证件的公钥基础设施是以通用的公钥基础设施标准为基础的，包括[X.509]和[RFC 5280]。这些基准公钥基础设施标准定义了一大套与电子机读旅行证件应用并不相关的选择性特征和认证机构之间的复杂信任关系。Doc 9303 号文件的本部分概述了为电子机读旅行证件应用专门制定的标准。电子机读旅行证件应用的一些独特方面包括：

- 每一签发国仅有一个国家签名认证机构；

- 认证路径仅包含一个证书（如证件签名者）；
- 在创立之后 5-10 年内必须能够进行签名验证；
- 支持国家签名认证机构更名；和
- 在认证路径中，国家签名认证机构链接证书不作为中间证书处理。

在大多数情况下，电子机读旅行证件的公钥基础设施与[RFC 5280]是一致的。然而，国家签名认证机构可以更名这一点对电子机读旅行证件公钥基础设施提出了独特要求，这些要求与[RFC 5280]中规定的一些证书撤销列表确认程序并不相符。已将这样的差异保持在最低限度，并对其进行了明确说明。

Doc 9303 号文件第 12 部分规定了电子机读旅行证件公钥基础设施的概要，其中包括：

- 基础设施中各实体的作用和责任；
- 加密算法和密钥管理；
- 证书和证书撤销列表的内容；
- 证书和证书撤销列表的分发机制；和
- 认证路径确认。

3. 作用和责任

电子机读旅行证件中所存储数据的真实性和完整性由被动认证保护。这一安全机制以数字签名为依据，包含下列公钥基础设施实体：

- **国家签名认证机构（CSCA）**：每一个签发国/签发机构建立单一的一个国家签名认证机构作为其在电子机读旅行证件方面的国家信任点。该国家签名认证机构为一个或多个（国家）证件签名者签发公钥证书，以及选择性地为国家证书列表签名者和偏差列表签名者等其他终端实体签发公钥证书。国家签名认证机构还定期发布证书撤销列表（CRL），说明所签发的证书是否有被撤销的。
- **证件签名者（DS）**：证件签名者用数字方式签署要存储在电子机读旅行证件中的数据；该签名存储在电子机读旅行证件的证件安全对象中。
- **查验系统（IS）**：查验系统用于验证数字签名，包括认证路径确认，以作为被动认证的一部分验证存储在电子机读旅行证件中的电子数据的真实性和完整性。
- **国家证书列表签名者**：国家证书列表签名者是通过电子方式签署国家签名认证机构证书（国内和国外）列表的一个选择性实体，以支持国家签名认证机构证书的双边分发机制。
- **证书列表签名者**在 Doc 9303 号文件第 3 部分进行了定义。

用于生成密钥对的安全设施应在签发国或签发机构的控制之下。每一个密钥对包括一个“私钥”和一个“公钥”。私钥及相关系统或设施应妥善保护好，以免被任何外部人员或未经授权的人员通过固有的设计和硬件安全设施获取到。

尽管国家签名认证机构的证书是相对稳定的，但是随着时间的推移，将产生大量证件签名者证书。

每一个签发国或签发机构的国家签名认证机构充当接收国的信任点。签发国或签发机构以证书的形式将其自己的国家签名认证机构公钥分发给接收国。接收国通过带外方式确定这一证书（和经认证的密钥）为“可信的”，并为该可信的密钥/证书存储一个“信任锚”。这些国家签名认证机构证书应该是由国家签名认证机构直接签发的自签名证书。国家签名认证机构证书不得为较大公钥基础设施中的从属证书或交叉证书。还可以签发国家签名认证机构自签名链接证书，以帮助接收国在密钥更替后对国家签名认证机构的新密钥/证书建立信任。

注：一些国家要求有一个认证机构中央管控者（CCA）作为向所有应用发布自签名证书的最高机构。在此类情况下，一个可能的解决方案是由国家签名认证机构创建自签名证书（满足国际民航组织 Doc 9303 号文件的要求），并请认证机构管控者会签该证书（满足该国自己的认证机构管控者要求）。但是这种会签证书不是电子机读旅行证件公钥基础设施中的一部分，不会被分发给接收国。

3.1　国家签名认证机构

建议在保护严密的线下认证机构基础设施中生成和存储国家签名认证机构密钥对（KPu_{CSCA}、KPr_{CSCA}）。

国家签名认证机构私钥（KPr_{CSCA}）用于签署证件签名者证书（C_{DS}）、其他证书和证书撤销列表。

国家签名认证机构证书（C_{CSCA}）用于确认证件签名者证书、国家证书列表签名者证书、偏差列表签名者证书、证书撤销列表和国家签名认证机构签发的其他证书。

所有证书和证书撤销列表必须符合第 7 节所规定的概要，且必须使用第 5 节所规定的分发机制进行分发。

对于公钥目录参与国，还必须将每一个国家签名认证机构证书（C_{CSCA}）发送给公钥目录（用于确认证件签发者证书（C_{DS}））。

如第 4 节所述，证书撤销列表必须定期发布。

3.2　证件签名者

建议在保护严密的基础设施中生成和存储证件签名者密钥对（KPu_{DS}、KPr_{DS}）。

证件签名者私钥（KPr_{DS}）用于签署证件安全对象（SO_D）。

证件签名者证书（C_{DS}）用于确认证件安全对象（SO_D）。

每一个证件签名者证书（C_{DS}）均必须符合第 7 节中所规定的证书概要，且必须存储于用相应的证件签名者私钥签署的每一个电子机读旅行证件的非接触式集成电路中（详见 Doc 9303 号文件第 10 部分）。这可确保接收国获取到与每一个电子机读旅行证件相关的证件签名者证书。

公钥目录参与国的证件签名者证书还应发送给国际民航组织，以便公布在国际民航组织公钥目录（PKD）中。

3.3 查验系统

查验系统用于进行被动认证，以确保存储在电子机读旅行证件非接触式集成电路中的数据的完整性和真实性。作为该过程的一部分，查验系统必须进行第 6 节所示的认证路径确认。

3.4 国家证书列表签名者

国家证书列表签名者私钥用于签署国家签名认证机构国家证书列表。

国家证书列表签名者证书用于确认国家签名认证机构国家证书列表。

3.5 偏差列表签名者

偏差列表签名者私钥用于签署偏差列表。

偏差列表签名者证书用于确认偏差列表。

4. 密钥管理

签发国或签发机构应至少有两个密钥对类型：

- 国家签名认证机构密钥对；和
- 证件签名者密钥对。

签发国或签发机构可以有额外类型的密钥对：

- 国家证书列表签名者密钥对；和
- 偏差列表签名者密钥对。

国家签名认证机构、证件签名者、国家证书列表签名者和偏差列表签名者公钥用[X.509]证书进行签发。国家签名认证机构证书中所包含的公钥用于验证已签发证书（证件签名者、国家证书列表签名者、偏差列表签名者和国家签名认证机构）上的国家签名认证机构的签名和已发布证书撤销列表上的签名。证件签名者证书中所包含的公钥用于验证该证件签名者使用相应的私钥在证件安全对象（SO_D）上创建的数字签名。国家证书列表签名者证书中所包含的公钥用于验证国家证书列表上的数字签名。偏差列表签名者证书中所包含的公钥用于验证偏差列表上的数字签名（Doc 9303 号文件第 3 部分对偏差列表进行了界定）。

对于国家证书列表签名者、偏差列表签名者和通信密钥与证书而言，私钥的生命周期和证书的有效期由签发国或签发机构自行确定。

国家签名认证机构证书和证件签名者证书都有相应的私钥使用期限和公钥有效期，具体如表 1 所示。

表 1　密钥的使用期限和有效期

	私钥的使用期限	公钥的有效期 （假设护照有效期为 **10** 年）
国家签名认证机构	3-5 年	13-15 年
证件签名者	最长至 3 个月[1]	约 10 年
国家证书列表签名者	由签发国或签发机构自行确定	由签发国或签发机构自行确定
偏差列表签名者	由签发国或签发机构自行确定	由签发国或签发机构自行确定
通信	由签发国或签发机构自行确定	由签发国或签发机构自行确定

4.1　证件签名者密钥和证书

证件签名者私钥的使用期限比对应公钥的证件签名者证书的有效期要短很多。

4.1.1　证件签名者公钥有效期

证件签名者公钥的生命周期，即证书有效期，是通过将下列期限关联在一起来确定的：

- 对应的私钥用于签发电子机读旅行证件的期限长度，和；
- 根据该密钥签发的任何电子机读旅行证件的最长有效期[2]。

证件签名者证书（C_{DS}）应在该整个时期都有效，以便可以对电子机读旅行证件的真实性进行验证。然而，对应的私钥应该仅在有限的一段时间内用于签发证件；一旦用其进行签发的最后一份证件的有效期到期，将不再需要公钥。

4.1.2　证件签名者私钥签发期限

在部署其系统时，签发国或签发机构似宜考虑到一个证件签名者私钥将要签署的证件的数量。

签发国或签发机构可以部署一个或多个证件签名者，每个签名者都拥有自己独特的密钥对，该密钥对将在特定时间内保持有效。

1. 应注意的是，证件签名者证书中对应的 privateKeyUsage 扩展可以稍长点，以便允许重叠或满足制证要求。
2. 一些签发国或签发机构可能会在电子机读旅行证件生效之前签发证件，如在结婚后改变姓名时。在此类情况下，“任何电子机读旅行证件的最长有效期”包括该电子机读旅行证件的实际有效期（如 10 年）加上该电子机读旅行证件签发日期与其生效日期之间的最长时间。

为了最大程度地降低证件签名者证书被撤销时产生的业务持续成本，每天签发大量电子机读旅行证件的签发国或签发机构似宜：

- 使用一个使用期限很短的私钥；和/或
- 部署几个同时工作的并行证件签名者，每一个签名者都拥有自己的独特私钥和公钥证书。

每天签发少量电子机读旅行证件的签发国或签发机构可以选择部署单个证件签名者，还可以稍微延长一下私钥的使用期限。

无论每天签发的电子机读旅行证件的数量或同时工作的证件签名者的数量有多少，建议用于签署电子机读旅行证件的证件签名者私钥的最长有效期为三个月。

一旦使用特定私钥签署的最后一个证件制作完成，建议签发国或签发机构以可接受审计和问责的方式删除该私钥。

4.2 国家签名认证机构密钥和证书

国家签名认证机构私钥的使用期限比对应公钥的国家签名认证机构证书的有效期要短很多。

4.2.1 国家签名认证机构的公钥有效期

国家签名认证机构公钥的生命周期，即证书有效期，是通过将下列期限关联在一起来确定的：

- 对应的国家签名认证机构私钥用于签署证件签名者证书（C_{DS}）的期限长度；和
- 证件签名者公钥证书的密钥生命周期（见 4.1.1）。

4.2.2 国家签名认证机构私钥的签发有效期限

用于签署证书和证书撤销列表的国家签名认证机构私钥的使用期限是在下列各种要素之间达成的一种微妙平衡：

- 万一签发国或签发机构的国家签名认证机构私钥被破坏，那么所有电子机读旅行证件只要是由遭破坏的国家签名认证机构私钥进行签署的证件签名者密钥签发的，其有效性就会遭到质疑。因此，签发国或签发机构似宜保持非常短的签发有效期。
- 然而，保持很短的签发有效期将造成任何时候都存在大量有效的国家签名认证机构公钥。这可在边防处理系统中造成更加复杂的证书管理问题。

因此建议签发国或签发机构每 3 到 5 年对其密钥对进行一次替换。

4.2.3　国家签名认证机构密钥重发

国家签名认证机构密钥在整个系统中提供了信任点，若没有这些信任点，系统将会崩溃。因此，签发国或签发机构应谨慎地计划其国家签名认证机构密钥对的替换事宜。一旦初始国家签名认证机构签名私钥的签发有效期已过，签发国或签发机构将在任何时候总有至少两个国家签名认证机构证书（C_{CSCA}）同时有效。

签发国或签发机构必须向接收国通报其国家签名认证机构密钥更替计划。这种通报必须在密钥更替开始前 90 天进行。在对密钥进行更替后，应将新的国家签名认证机构证书（认证新的国家签名认证机构公钥）分发给各接收国。

如果国家签名认证机构证书是一个新的自签名证书，应该使用带外方法对该证书进行验证。

在对国家签名认证机构密钥进行更替后，必须签发一个证书，用于链接新旧密钥，以便各信赖方可以进行安全的过渡。一般的做法是签发一个自签发证书，其中签发者和主体域相同，而用于验证签名的密钥是旧密钥对，经认证的公钥是新密钥对。这些国家签名认证机构链接证书无需使用带外方法进行验证，因为这些证书上的签名可通过使用该国家签名认证机构已有的可信公钥进行验证。还可以使用国家证书列表分发国家签名认证机构链接证书和国家签名认证机构自签名根证书。

在国家签名认证机构密钥更替后的头两天，签发国或签发机构应尽量不要使用国家签名认证机构新私钥，以便确保对应的国家签名认证机构新公钥证书成功分发完成。

签发国或签发机构在签署证书（包括证件签名者证书）和签署证书撤销列表时必须使用最新的国家签名认证机构私钥。

4.3　证书撤销

如果出现事故（如密钥遭到破坏），签发国或签发机构可能需要撤销证书。

所有国家签名认证机构必须以证书撤销列表（CRL）的形式制作定期的撤销信息。

国家签名认证机构必须每 90 天至少发布一份证书撤销列表，即使自上次发布证书撤销列表之后没有撤销过任何证书也必须这么做。证书撤销列表的发布频率可以高于每 90 天一次，但是不得高于每 48 小时一次。

如果有证书被撤销，必须在 48 小时内分发一份证书撤销列表，标明被撤销的证书。

只有证书可以被撤销，证件安全对象不可被撤销。证书撤销列表的使用限于通报已撤销的由签发证书撤销列表的国家签名认证机构签发的证书（包括国家签名认证机构证书、证件签名者证书、国家证书列表签名者证书、偏差列表签名者证书和该认证机构签发的其他证书类型的撤销通知）。

电子机读旅行证件应用中不使用分区的证书撤销列表。一个国家签名认证机构撤销的所有证书，包括证件签名者证书、国家签名认证机构证书、国家证书列表签名者证书和偏差列表签名者证书，都列在同一个证书撤销列表中。尽管证书撤销列表总是由最新的（当前的）国家签名认证机构签名私钥签署，但证书撤销列表同时包括使用这一私钥签署的证书的撤销通知和使用国家签名认证机构早先签名私钥签署的证书的撤销通知。

4.3.1 国家签名认证机构证书的撤销

国家签名认证机构证书的撤销既极端罕见又不好处理。在告知接收国某一国家签名认证机构证书已被撤销后，使用对应的国家签名认证机构私钥签署的所有其他证书也被实际撤销。

当已经使用旧的国家签名认证机构私钥签署国家签名认证机构链接证书，以认证新的国家签名认证机构公钥时（见 4.2 节“国家签名认证机构密钥重发”），撤销旧的国家签名认证机构证书也应撤销新的国家签名认证机构证书。

如果需要撤销一个国家签名认证机构证书，该国家签名认证机构可以发布一份使用与要被撤销的公钥对应的私钥签署的证书撤销列表，因为这是此时证书撤销列表用户可以验证的唯一一个密钥。国家签名认证机构的这一公钥只有在用于验证该证书撤销列表的签名目的时，才应被认为是有效的。一旦证书撤销列表用户验证完证书撤销列表签名，国家签名认证机构的签名私钥便被认为已遭破坏，且证书将被撤销，未来不再用于验证目的。

为签发新的证件，签发国或签发机构必须重新从头启动认证过程，做法是：签发新的国家签名认证机构根证书，将该证书分发给各接收国，支持用带外方法确认每一个接收国所接收到的证书确实是真实的现行国家签名认证机构证书。

4.3.2 其他证书的撤销

当签发国或签发机构想要撤销证件签名者、国家证书列表签名者、偏差列表签名者或通信证书时，无需等到当前证书撤销列表中的 nextUpdate 开始时再发布新的证书撤销列表。建议在撤销通知发出后的 48 小时内发布新的证书撤销列表。

4.4 加密算法

签发国或签发机构必须支持在其国家证书签名认证机构和证件签名密钥中使用相同的算法，尽管根据所选择的算法可能需要不同的密钥大小。

签发国或签发机构应选择适当的密钥长度，以防范遭受攻击。应该考虑采用适当的加密目录。

接收国若希望确认电子机读旅行证件上的签名，必须支持所有算法。

为了能在其国家签名认证机构、证件签名密钥和证件安全对象（如适用）中使用下文所述的算法，签发国或签发机构应支持其中一种算法。

4.4.1 RSA 公钥算法

使用 RSA 算法生成签名以及验证证件和证件安全对象（SO_D）的签发国或签发机构应使用[RFC 4055]。[RFC 4055]规定了两种签名机制：RSASSA-PSS 和 RSASSA-PKCS1_v15。建议签发国或签发机构根据 RSASSA-PSS 生成签名，但接收国还必须可以根据 RSASSA-PKCS1_v15 验证签名。

4.4.2　数字签名算法（DSA）

使用数字签名算法生成签名或验证签名的签发国或签发机构应使用[FIPS 186-4]。

4.4.3　椭圆曲线数字签名算法（ECDSA）

使用椭圆曲线数字签名算法生成签名或验证签名的签发国或签发机构应使用[X9.62]或[ISO/IEC 15946]。用来生成椭圆曲线数字签名算法密钥对的椭圆曲线域参数必须在公钥参数中作出明确说明，即：参数必须为 ECParameters 型（无命名曲线，无隐含参数），并且必须包括选择性辅因子。ECPoints 必须为非压缩格式。

建议遵循[TR 03111]指导原则。

4.4.4　散列法算法

唯有 SHA-224、SHA-256、SHA-384 和 SHA-512 是允许采用的散列算法。见[FIPS 180-2]。

5.　分发机制

需要将公钥基础设施对象分发至各接收国。根据对象类型和运行要求的不同，可采用多种不同的分发机制。须注意的是，这些对象的分发并不建立对这些对象或与其相关的私钥/公钥的信任。有关建立信任的机制在第 6 节中进行了说明。

需要从签发国或签发机构分发到接收国的对象包括：

- 国家签名认证机构证书；
- 证件签名者证书；
- 证书撤销列表（空或非空）；
- 国家证书列表签名者证书；国家证书列表；和
- 偏差列表签名者证书。

在电子机读旅行证件公钥基础设施中使用的分发机制包括：

- 公钥目录；
- 双边交换；
- 国家证书列表；
- 偏差列表；和
- 电子机读旅行证件非接触式集成电路。

如表 2 所示，为每一个对象规定了主要和次要（如适用）分发机制。

表 2　主要和次要分发机制

	国家签名认证机构证书	证件签名者证书	证书撤销列表（空和非空）	国家证书列表签名者证书	国家证书列表	偏差列表签名者证书
主要	双边	电子机读旅行证件非接触式集成电路	双边	国家证书列表	公钥目录/双边	偏差列表
次要	国家证书列表	公钥目录	公钥目录			

从操作上讲，接收国不必非得既使用主要方法，也使用次要方法。在查验系统的每日操作中，查验机构可自行决定是使用主要方法，还是使用次要方法。如果接收国的相关机构在其日常操作中使用次要方法验证证书或证书撤销列表，则该机构也应该做好支持主要方法的准备。

签发国或签发机构需要为国家签名认证机构密钥和证件签名者密钥制定密钥对更替策略，以便能够使证书和证书撤销表及时传送到接收国的边防控制系统中。传送最好在 48 小时之内进行，但是一些接收国的边防检查哨所可能比较偏远，联络不畅，可能需要更多的时间才能将证书和证书撤销表传送出去。接收国应该竭尽全力将这些证书和证书撤销表在 48 小时之内分发到所有的边防检查站。

签发国或签发机构应该要求接收国将在 48 小时之内将国家签名认证机构证书（C_{CSCA}）传送出去。

通过将证件签名者证书（C_{DS}）包括在证件安全对象（SO_D）中，签发国或签发机构能够确保证件签名者证书（C_{DS}）的及时传送。签发国或签发机构还应该要求在 48 小时之内将公钥目录中公布的证件签名者证书（C_{DS}）传送至边防检查站。

接收国应该竭尽全力通过电子或其他手段执行证书撤销列表，包括那些在特殊情况下发布的证书撤销表。

可通过将国家证书列表签名者证书（C_{DS}）包含在每次的国家证书列表中来确保其及时传送出去。

5.1　公钥目录分发机制

国际民航组织提供了一项公钥目录（PKD）服务。这一服务应接受各种公钥基础设施对象，包括来自于公钥目录参与国的证书、证书撤销列表和国家证书列表，将它们存储在一个目录中，并让所有接收国都可以获得这些对象。

国家签名认证机构证书（C_{CSCA}）并不作为国际民航组织公钥目录服务的一部分单独存储。然而，如果将它们载于国家证书列表中，它们是可以出现在公钥目录中的。

每一个证件签名者证书（C_{DS}）在公钥目录中保留至其证书有效期到期，无论对应的私钥是否还在用。

所有公钥目录参与国存储在公钥目录中的证书、证书撤销列表和国家证书列表应对需要使用该信息确认通过数字方式存储的电子机读旅行证件数据的真实性和完整性的各方（包括非公钥目录参与国）提供。

5.1.1　公钥目录的上传

仅公钥目录参与国可以将证书、证书撤销列表和国家证书列表上传至公钥目录。所有证书和证书撤销列表必须符合第 7 节中的概要。所有国家证书列表必须遵守第 8 节中的规范。

公钥目录由“写入目录”和“读取目录”组成。公钥目录参与国应使用轻量级目录访问协议（LDAP）将他们的对象上传至写入目录。一旦对一个对象进行了电子签名验证，且完成了其他例行检查，该对象便会发布在读取目录中。

5.1.2　公钥目录的下载

应该向公钥目录参与国和非参与国提供读取公钥目录中公布的所有证书、证书撤销列表和国家证书列表的权限。不得对公钥目录的读取实施访问控制。

接收国应负责将从公钥目录中下载的对象分发至其查验系统，并且应维持一个证书撤销列表当前缓存区和验证电子机读旅行证件数据上的签名所需用到的证书。

5.2　双边交换分发机制

对于证书撤销列表和国家证书签名认证机构证书（C_{CSCA}），主要分发渠道是签发国或签发机构和接收国之间的双边交换。双边交换也可用于分发国家证书列表。

用于这种双边交换的具体技术可能因每一个需要分发其证书、证书撤销列表和国家证书列表的签发国或签发机构的政策以及需要使用这些对象的每一个接收国的政策而异。可用于双边交换的技术的一些例子包括：

- 外交信使/外交邮袋；
- 电子邮件交换；
- 从与进行签发的国家签名认证机构相关的网站进行下载；和
- 从与进行签发的国家签名认证机构相关的轻量级目录访问协议服务器上进行下载。

这并非详尽的列表，还可以使用其他技术。

5.3　国家证书列表分发机制

国家证书列表是双边分发机制的一种支持技术。因此，通过国家证书列表分发国家签名认证机构证书是双边分发机制的一种方法。

国家证书列表是发布该列表的接收国所“信任的”国家签名认证机构证书的一个经数字签名的列表。国家签名认证机构自签名根证书和国家签名认证机构链接证书可以纳入国家证书列表中。国家证书列表的结构和格式在第 8 节进行了规定。公布国家证书列表可以让其他接收国从一个单一来源（国家证书列表发布者）获得一套国家签名认证机构证书，而不用与在该列表上出现的每一个签发机关或签发机构达成直接双边交换协议。

国家签名认证机构授权国家证书列表签名者编制、通过数字方式签署和发布国家证书列表。国家证书列表不得由国家签名认证机构自己直接签名和发布。国家证书列表签名者证书必须符合第 7 节中所规定的证书概要。

在发布国家证书列表之前，负责发布的国家证书列表签名者应该广泛地确认将要被会签的国家证书签名认证机构的证书，包括确保这些证书确实属于所确定的国家签名认证机构。用于这种带外确认的程序应该在签发该国家证书列表签名者证书的国家签名认证机构的公布的证书政策中予以反映。

每一个国家证书列表必须包括国家证书列表签名者证书，该证书将被用于验证该国家证书列表上的签名以及签发该国家证书列表签名者证书的国家签名认证机构的证书。

如果接收国收到新的国家签名认证机构证书，且已经完成确认程序，则建议编制和发布新的国家证书列表。

对于一些接收国而言，使用国家证书列表确实可以使国家签名认证机构证书的分发变得更为高效。然而，使用国家证书列表的接收国仍旧必须确定关于对该列表内所载证书建立信任的相关政策（详见第 6 节）。

6. 公钥基础设施的信任和确认

在电子机读旅行证件公钥基础设施的环境中，接收国的查验系统扮演公钥基础设施信赖方的角色。对电子机读旅行证件的证件安全对象上电子签名的成功验证可确保存储于该电子机读旅行证件的非接触式集成电路中的数据的真实性和完整性。签名验证过程要求信赖方确定用于验证签名的证件签名者公钥本身是“可信的”。

通过第 5 节中界定的各种分发机制，接收国可以获得验证所涉数字签名所需的证书和证书撤销列表。然而，这些分发机制不对这些证书、证书撤销列表或用于验证这些证书和证书撤销列表上签名的公钥建立信任。

国家签名认证机构证书（C_{CSCA}）中所载的公钥用于验证证书（包括证件签名者国家证书列表签名者和偏差列表签名者证书）和证书撤销列表上的数字签名。因此，在接受另一个签发国的电子机读旅行证件时，接收国必须已经将签发国或签发机构的国家签名认证机构证书（C_{CSCA}）的一个受信任副本或者从该证书获得的关于该国家签名认证机构公钥的其他形式的信任锚信息放入某种形式的信任库，其边防管制系统应可以使用该信任库。

接收国有责任以安全的方式对国家签名认证机构证书（C_{CSCA}）建立信任并将该证书（或来自该证书的信息）存储为信任锚，供其边防查验系统使用。

6.1　信任锚的管理

正如[RFC 5280]所规定的，必须建立一个信任锚，用于确定一特定证件签名者、国家证书列表签名者、偏差列表签名者或其他类型证书的确认程序。

每一个信任锚由一个可信的公钥和相关的元数据组成。信任锚必须至少包括下列内容：

- 可信的公钥和任何相关的密钥参数；
- 公钥算法；
- 密钥所有者的名称；和
- 国家签名认证机构证书包含国际民航组织分配的签发机关或机构三字代码的“SubjectAltName”扩展的值。尽管这方面的信息不用于证书路径或证书撤销列表确认程序中，但是用于 Doc 9303 号文件第 11 部分中定义的被动验证。

在电子机读旅行证件应用中，对特定国家签名认证机构的每一个公钥都建立一个单独的信任锚。对于从国家签名认证机构获得的初始公钥，必须通过带外机制建立信任。例如，如果从与国家签名认证机构相关的服务器上下载一个国家签名认证机构证书，可采用带外通信（如电话或电子邮件）来验证所下载的证书实际上是该国家签名认证机构的真实证书。另外，信赖方可以分析进行签发的国家签名认证机构的政策、程序和做法，以确定其是否足够安全，可以满足使用证书的当地要求。一旦为特定国家签名认证机构建立了初始信任锚，便可对该国家签名认证机构后续密钥的处理过程进行简化。如果该国家签名认证机构签发了一个国家签名认证机构链接证书，那么可以省去通过带外方式与该国家签名认证机构进行通信以验证新证书的真实性，因为可以使用该国家签名认证机构的已经获得信任的公钥来验证该链接证书上的签名。

信任锚信息可以为国家签名认证机构证书的一个可信副本，或其他一种可信格式。

由于国家签名认证机构所签发证书上的签名需要在该国家签名认证机构更新其密钥对后的很长时间内可以验证，因此，接收国通常会在同一时间有多个针对同一国家签名认证机构的信任锚。如果国家签名认证机构已经更名，这些信任锚中有一些将包含旧的国家签名认证机构名称，其他信任锚则将包含新的名称。

6.2　证书/证书撤销列表确认和撤销检查

作为验证电子机读旅行证件应用中数据对象（如证件安全对象、国家证书列表、偏差列表等）的真实性和完整性的过程的一部分，接收国应：

- 确认用于验证数据对象（如证件签名者证书、国家证书列表签名者证书、偏差列表签名者证书）上签名的证书；
- 确认用于检查所涉证书的撤销状态的证书撤销列表；和
- 处理证书撤销列表，以便验证所涉证书的撤销状态。

现在已有可用于这些过程的示范算法，如[RFC 5280]中规定的算法。接收国无需采用 RFC 5280 中定义的具体算法，但是所提供的功能必须与这一程序的外部性能相当。在具体操作时，可以采用任何算法，只要该算法可以推导出正确的结果。

附录 D 为选择[RFC 5280]中规定的算法作为自己算法的依据的接收国提供了指导。

7. 证书和证书撤销列表概要

签发国或签发机构必须签发符合下文所规定概要的证书和证书撤销列表。所有证书和证书撤销列表必须使用唯一编码规则（DER）格式制作，以保护其中签名的完整性。本规范第六版中所载的关于国家签名认证机构和证件签名者证书的概要在一些地方与当前概要存在不同。查验系统必须能够处理根据早先概要（见附录 C）以及当前概要签发的证书。

这些概要是基于这样的要求制定的：每一个签发国或签发机构或实体应建立单一的一个国家签名认证机构负责签署符合 Doc 9303 号文件规定的所有机读旅行证件。

第 7.1 节针对下列证书类型规定了证书概要：

- 国家签名认证机构；
- 证件签名者；
- 国家签名认证机构国家证书列表签名者；
- 偏差列表签名者；和
- 通信 — 即使严格来讲其并不是现在所需的。这是未来用于验证的一个步骤。这些证书可用于访问公钥目录或用于各国之间的 LDAP/EMAIL/HTTP 通信。建议由国家签名认证机构签发这类证书。

国家签名认证机构、证件签名者和国家签名认证机构国家证书列表签名者对象在第 3 节中进行了规定。偏差列表签名者对象在 Doc 9303 号文件第 3 部分中进行了规定。

证书撤销列表概要在第 7.2 节中进行了规定。

对于每一个组成部分/扩展的存在要求，这些概要使用下列术语进行表示：

m 强制性 — 该域必须存在；
x 不使用 — 该域不得存在；
o 选择性 — 该域可以存在。

对于可以/必须包括在内的扩展的关键性要求，这些概要使用下列术语进行表示：

c 关键的 — 接收应用必须能够处理该扩展；
nc 非关键的 — 接收应用若不理解该扩展，可将其忽略。

这些概要中确定的一些要求是从所参考的基准概要（如 RFC 5280）中沿用而来的。为方便起见，附录 B 中的表格对涉及具体要求的基准概要中的相关文字进行了抄录。

7.1　证书概要

表 3 规定了证书主体各个域的证书概要要求。表 4 规定了证书扩展要求。

表 3　证书各域概要

证书组成部分	是否应存在	注释
Certificate	m	
TBSCertificate	m	见本表的下一部分
signatureAlgorithm	m	这里插入的值取决于所选择的算法
signatureValue	m	这里插入的值取决于所选择的算法
TBSCertificate		
version	m	**必须**为 v3
serialNumber	m	必须为正整数且最大为 20 个八位位组 必须使用二进制补码且以最少的八位位组表示
signature	m	这里插入的值必须和 Certificate 序列的 signatureAlgorithm 组成部分的值相同
issuer	m	如果存在 countryName 和 serialNumber，必须为 PrintableString 有 DirectoryString 句法的其他属性必须为 PrintableString 或 UTF8String countryName 必须为大写字母 见第 7.1.1 节的命名规则
validity	m	必须以 Z 结束 必须存在秒元素

证书组成部分	是否应存在	注释
		2049 年及以前的日期必须为 UTCTime UTCTime 必须以 YYMMDDHHMMSSZ 表示 2050 年及以后的时间必须为 GeneralizedTime GeneralizedTime 不得有小数秒 GeneralizedTime 必须以 YYYYMMDDHHMMSSZ 表示
subject	m	如果存在 countryName 和 serialNumber，必须为 PrintableString 有 DirectoryString 句法的其他属性必须为 PrintableString 或 UTF8String countryName 必须为大写字母 issuer 域和 subject 域中的 countryName 必须匹配 见第 7.1.1 节的命名规则
subjectPublicKeyInfo	m	
issuerUniqueID	x	
subjectUniqueID	x	
extensions	m	见关于应该存在哪些扩展的下表 扩展的缺省值不得编码

表 4　证书扩展概要

扩展名称	国家签名认证机构自签名根		国家签名认证机构链接		证件签名者		国家证书列表签名者和偏差列表签名者		通信		注释
	是否应存在	关键性	是否应存在	关键性	是否应存在	关键性	是否应存在	关键性	是否应存在	关键性	
AuthorityKeyIdentifier	**o**	**nc**	**m**	**nc**	**m**	**nc**	**m**	**nc**	**m**	**nc**	
keyIdentifier	m		m		m		m		m		
authorityCertIssuer	o		o		o		o		o		
authorityCertSerialNumber	o		o		o		o		o		
SubjectKeyIdentifier	**m**	**nc**	**m**	**nc**	**o**	**nc**	**o**	**nc**	**o**	**nc**	
subjectKeyIdentifier	m		m		m		m		m		
KeyUsage	**m**	**c**	**m**	**c**	**m**	**c**	**m**	**c**	**m**	**c**	
digitalSignature	x		x		m		m		o		一些通信证书（如传输层安全证书）要求按照所使用的特定加密套件来设置 keyUsage 位。一些加密套件要求设置 digitalSignature 位，一些则不要求。
nonRepudiation	x		x		x		x		x		
keyEncipherment	x		x		x		x		o		
dataEncipherment	x		x		x		x		x		
keyAgreement	x		x		x		x		o		
keyCertSign	m		m		x		x		x		
cRLSign	m		m		x		x		x		
encipherOnly	x		x		x		x		x		
decipherOnly	x		x		x		x		x		
PrivateKeyUsagePeriod	**m**	**nc**	**m**	**nc**	**m**	**nc**	**o**	**nc**	**o**	**nc**	
notBefore	o		o		o		o		o		notBefore 和 notAfter 中必须至少出现一个
notAfter	o		o		o		o		o		必须编码为 generalizedTime

扩展名称	国家签名认证机构自签名根		国家签名认证机构链接		证件签名者		国家证书列表签名者和偏差列表签名者		通信		注释
CertificatePolicies	**o**	**nc**	**o**	**nc**	**o**	**nc**	**o**	**nc**	**o**	**nc**	
PolicyInformation	m		m		m		m		m		
policyIdentifier	m		m		m		m		m		
policyQualifiers	o		o		o		o		o		
PolicyMappings	**x**		**x**		**x**		**x**		**x**		见注 1
SubjectAltName	**m**	**nc**	**m**	**nc**	**m**	**nc**	**m**	**nc**	**m**	**nc**	见第 7.1.2 节
IssuerAltName	**m**	**nc**	**m**	**nc**	**m**	**nc**	**m**	**nc**	**m**	**nc**	见第 7.1.2 节
SubjectDirectoryAttributes	**x**		**x**		**x**		**x**		**x**		
Basic Constraints	**m**	**c**	**m**	**c**	**x**		**x**		**x**		
cA	m		m		x		x		x		
PathLenConstraint	m		m		x		x		x		必须始终为“0”
NameConstraints	**x**		**x**		**x**		**x**		**x**		见注 1
PolicyConstraints	**x**		**x**		**x**		**x**		**x**		见注 1
ExtKeyUsage	**x**		**x**		**x**		**m**	**c**	**m**	**c**	见第 7.1.3 节
CRLDistributionPoints	**m**	**nc**	**m**	**nc**	**m**	**nc**	**m**	**nc**	**o**	**nc**	
distributionPoint	m		m		m		m		m		必须为 ldap、 http 或 https 见第 7.1.4 节
reasons	x		x		x		x		x		
cRLIssuer	x		x		x		x		x		
InhibitAnyPolicy	**x**		**x**		**x**		**x**		**x**		见注 1
FreshestCRL	**x**		**x**		**x**		**x**		**x**		见注 2
privateInternetExtensions	**o**	**nc**	**o**	**nc**	**o**	**nc**	**o**	**nc**	**o**	**nc**	见注 3
NameChange	**o**	**nc**	**o**	**nc**	**x**		**x**		**x**		见第 7.1.5 节
DocumentType	**x**		**x**		**m**	**nc**	**x**		**x**		见第 7.1.6 节
Netscape Certificate Type	**x**		**x**		**x**		**x**		**x**		见注 4
other private extensions	**o**	**nc**	**o**	**nc**	**o**	**nc**	**o**	**nc**	**o**	**nc**	

注 1：按照定义，扩展只可以出现在中间认证机构证书上（一个认证机构向另外一个认证机构签发的证书）。中间认证机构证书不用在电子机读旅行证件的公钥基础设施中。因此电子机读旅行证件证书中禁用这种扩展。

注 2：使用最新的证书撤销列表扩展指向增量证书撤销列表。电子机读旅行证件的公钥基础设施不支持增量证书撤销列表。因此禁用这种扩展。

注 3：RFC 5280 中规定了两种专用因特网扩展（机构信息访问和主体信息访问），用于指向与证书签发者或证书主体相关的信息。这些扩展不要求出现在电子机读旅行证件的公钥基础设施中。然而，由于它们不影响互操作性，且是非关键的，因此可以选择性地将其包括进电子机读旅行证件证书当中。

注 4：网景证书类型扩展可用来限制一个证书的使用用途。extKeyUsage 和 basicConstraints 扩展是当前用于表示这种用途的标准扩展，且用在电子机读旅行证件应用中。由于标准扩展和网景专用扩展的值之间存在潜在冲突，因此禁用网景扩展。

7.1.1　关于签发者和主体域的要求

要求遵守关于 Issuer 和 Subject 域的下列命名和寻址规则。

- countryName 必须存在。该值包含一个国家代码，该代码必须遵守[ISO 3166-1]中所规定的两字国家代码格式
- commonName 必须存在。

签发国或签发机构还可自行决定纳入其他属性。

7.1.2　关于签发者和主体替代名称的要求

由于电子机读旅行证件应用中的替代名称所发挥的功能是专门针对这种应用且不同于[RFC 5280]中为因特网公钥基础设施所规定的功能，因此电子机读旅行证件证书的主体替代名称扩展通常不会清楚地表明证书主体。

在电子机读旅行证件应用中，替代名称发挥下列两种功能。

第一种功能是提供证书的主体和/或签发者的联系信息。为此，它应该至少包括下列内容：

- rfc822Name；
- dNSName；或
- uniformResourceIdentifier.

第二种功能是提供一个由国际民航组织所分配的国家代码组成的目录字符串。为此，使用该概要签发的证书必须额外地包括一个按如下方式构成的目录名称：

- 包含国际民航组织国家代码的 localityName，该代码应与机读区中所示的一样；和

- 如果这一国家代码无法作为签发国或签发机构的唯一识别信息，则应该使用 stateOrProvinceName 这一属性来表示国际民航组织分配的该签发国或签发机构三字代码。

- 不允许使用其他属性。

在国家签名认证机构的自签名根证书中，IssuerAltName 和 SubjectAltName 扩展必须是相同的。在国家签名认证机构链接证书中，这些值可以不同。例如，如果国家签名认证机构的 rfc822Name 在快要签发国家签名认证机构链接证书之前发生了变化，则 IssuerAltName 扩展将包含旧的 rfc822Name，而 SubjectAltName 扩展将包含新的 rfc822Name。任何后续的国家签名认证机构链接证书将在两个扩展中包含新的 rfc822Name。

7.1.3 关于延长密钥使用期限扩展的要求

国家证书列表签名者证书的 extendedKeyUsage 扩展中必须包括的对象标识符（OID）为 2.23.136.1.1.3。

偏差列表签名者证书的 extendedKeyUsage 扩展中必须包括的对象标识符（OID）为 2.23.136.1.1.8。

对于通信证书而言，这一扩展的值取决于所使用的通信协议（见 RFC 5280 第 4.2.1.12 节）。

7.1.4 关于证书撤销列表分发点扩展的要求

国家签名认证机构可以在多个地方公布其证书撤销列表，包括公钥目录、自己的网站等。

对于在公钥目录以外地方（例如网站或本地轻量目录访问协议服务器）公布的证书撤销列表，这一扩展中要包括的值受签发相关证书和证书撤销列表的国家签名认证机构的控制。

对于提交给公钥目录的证书撤销列表，公钥目录参与国可以使用下列模板针对其证书撤销列表纳入两个 URL 值（用国际民航组织分配的签发国或签发机构三字代码代替“CountryCode”）。如果该国家代码无法作为签发国或签发机构的唯一识别信息，则通过下列方式输入内容：在机读区中的三字国家代码上附加“_”符号，接着输入可作为该签发国或签发机构唯一识别信息的国际民航组织分配的该签发国或签发机构三字代码。

https://pkddownload1.icao.int/CRLs/CountryCode.crl
https://pkddownload2.icao.int/CRLs/CountryCode.crl

这是一种强制扩展，并且撤销状态检查是确认程序的一个强制部分。因此必须至少填写其中的一个值。

- 公钥目录的值可能是扩展中仅有的值；

- 可能会有额外的值（例如，国家签名认证机构可能也会选择在网站上公布其证书撤销列表并包括一个指向该来源的指示标）；或

- 即使国家签名认证机构也将其证书撤销列表提交给公钥目录，该机构也可能选择仅包括单个值（例如，指向其网站来源的指示标）。

下列示例说明了新加坡和香港签发机构所签发的证书中要填写的公钥目录的值：

新加坡公钥目录示例：
https://pkddownload1.icao.int/CRLs/SGP.crl
https://pkddownload2.icao.int/CRLs/SGP.crl

香港示例：
https://pkddownload1.icao.int/CRLs/CHN_HKG.crl
https://pkddownload2.icao.int/CRLs/CHN_HKG.crl

7.1.5　名称变更扩展

当对国家签名认证机构密钥进行更替时，必须签发一个将旧公钥与新公钥链接起来的证书，以便为信赖方提供安全的过渡。通常，这是通过签发自签发证书实现的，在该证书中，issuer 和 subject 这两个域是相同的，但是用于验证签名的密钥是旧的密钥对，经认证的公钥是新密钥对。

建议国家签名认证机构不要无谓地更改它们的唯一甄别名（DN），因为这会对信赖方产生负面影响（它们必须为同一签发国或签发机构保留新旧两种名称，作为有效的国家签名认证机构，直至旧名称之下的所有电子机读护照失效）。然而，如果确需更名，必须通过签发国家签名认证机构链接证书将相关情况传送给信赖方，在该证书中，issuer 域包含旧名称，subject 域包含新名称。这一国家签名认证机构链接证书也可以传送有关密钥更替的信息，其中用于验证签名的密钥是旧密钥对，而经认证的公钥是新密钥对。既用于传达国家签名认证机构名称变更又用于传达该机构的密钥更替情况的证书必须包含 NameChange 扩展，以便表明该证书的这种性质。这对 PathLengthConstraint 没有影响，它仍旧是“0”。

此外，NameChange 扩展也可以包括在国际签名认证机构唯一甄别名发生变化时创建的新的国家签名认证机构自签名证书中。在这样的自签名国家签名认证机构根证书中，issuer 和 subject 域均包含新的唯一甄别名。不同于同时包含国家签名认证机构新旧唯一甄别名的国家签名认证机构自签发链接证书，将 NameChange 包括进国家签名认证机构自签名根证书只是表明已经发生了更名，并不将新旧唯一甄别名链接起来。

国家签名认证机构不得重复使用证书序列号。国家签名认证机构所签发的每一份证书，无论该机构是否更过名，都必须是唯一的。

用于更名扩展的 ASN.1：

```
nameChange EXTENSION ::= {
    SYNTAX                      NULL
    IDENTIFIED BY           id-icao-mrtd-security-extensions-nameChange}

id-icao-mrtd-security-extensions OBJECT IDENTIFIER ::= {id-icao-
mrtd-security 6}
id-icao-mrtd-security-extensions-nameChange OBJECT IDENTIFIER ::=
{id-icao-
mrtd-security-extensions 1}
```

7.1.6 证件类型扩展

必须使用 DocumentType 扩展来表示对应的证件签名者可以制作的证书类型，该类型应该与机读区上所示的信息一样。该扩展必须始终被设定为非关键的。

证件类型列表扩展的 ASN.1：

```
documentTypeList EXTENSION ::= {
    SYNTAX                  DocumentTypeListSyntax
    IDENTIFIED BY           id-icao-mrtd-security-extensions-documentTypeList}

DocumentTypeListSyntax ::= SEQUENCE {
    version             DocumentTypeListVersion,
    docTypeList         SET OF DocumentType }

DocumentTypeListVersion ::= INTEGER {v0(0)}

— 证件类型和机读区所载类型一样，如其中“P”或“ID”
— 每个单一字母表示以该字母打头的所有证件类型
DocumentType ::= PrintableString(1..2)

id-icao-mrtd-security-extensions-documentTypeList OBJECT
IDENTIFIER ::= {id-icao-mrtd-security-extensions 2}
```

7.2 证书撤销列表概要

表 5 规定了证书撤销列表主体部分各个域的证书撤销列表概要要求。表 6 规定了关于证书撤销列表和证书撤销列表输入扩展的证书撤销列表概要要求。

表 5 证书撤销列表各个域的概要

证书列表组成部分	国家签名认证机构 证书撤销列表	注释
CertificateList	m	
tBSCertList	m	见本表的下一部分
signatureAlgorithm	m	这里插入的值取决于所选择的算法
signatureValue	m	这里插入的值取决于所选择的算法
tBSCertList		
version	m	必须为 v2

证书列表组成部分	国家签名认证机构 证书撤销列表	注释
signature	m	这里插入的值必须和 CertificateList 序列的 signatureAlgorithm 组成部分的值相同
issuer	m	如果存在 countryName 和 serialNumber，必须为 PrintableString 有 DirectoryString 句法的其他属性必须为 PrintableString 或 UTF8String countryName 必须为大写字母
thisUpdate	m	必须以 Z 结束 必须存在秒元素 2049 年及以前的时间必须为 UTCTime UTCTime 必须以 YYMMDDHHMMSSZ 表示 2050 年及以后的时间必须为 GeneralizedTime GeneralizedTime 不得有小数秒 GeneralizedTime 必须以 YYYYMMDDHHMMSSZ 表示
nextUpdate	m	必须以 Z 结尾 必须存在秒元素 2049 年及以前的时间必须为 UTCTime UTCTime 必须以 YYMMDDHHMMSSZ 表示 2050 年及以后的时间必须为 GeneralizedTime GeneralizedTime 不得有小数秒 GeneralizedTime 必须以 YYYYMMDDHHMMSSZ 表示
revokedCertificates	m	如果存在，不得为空白
crlExtensions	m	见关于应该存在哪些扩展的下表 扩展的缺省值不得编码

表 6　证书撤销列表和证书撤销列表输入扩展概要

扩展名称	国家签名认证机构证书撤销列表	关键性	注释
证书撤销列表扩展			
authorityKeyIdentifier	**m**	**nc**	该项必须与证书撤销列表签发者证书的 subjectKeyIdentifier 域中的值相同
keyIdentifier	m		
authorityCertIssuer	o		
authorityCertSerialNumber	o		
issuerAlternativeName	**o**	**nc**	见注 1
cRLNumber	**m**	**nc**	必须为非负整数且最大为 20 个八位位组 必须使用二进制补码且以最少的八位位组表示
deltaCRLIndicator	**x**		
issuingDistributionPoint	**x**		
freshestCRL	**x**		
CRL Entry Extensions			
reasonCode	**x**		
holdInstructionCode	**x**		
invalidityDate	**x**		
certificateIssuer	**x**		

注 1：如果一国家签名认证机构经历了更名，这一扩展可以包括进国家签名认证机构更名后签发的证书撤销列表中。如果存在这一扩展，其中的值必须与该国家签名认证机构在之前的名称下签发的证书的 issuer 域相同。一旦在国家签名认证机构之前的名称下签发的所有证书均已过期，可将该国家签名认证机构的名称从后续的证书撤销列表中剔除。不要求查验系统处理这一扩展。鉴于国际民航组织的 Doc 9303 号文件规定每个国家只能有一个国家签名认证机构，签发者域的 countryName 这一组成部分足以作为该国家签名认证机构的唯一识别信息。用该国家签名认证机构的最新公钥验证证书撤销列表上的签名。由于一个国家签名认证机构签发一份单一的证书撤销列表，因此该证书撤销列表涵盖使用该 countryName 签发的所有证书。除了这种强制检查之外，还可以进行选择性检查，检查证书的 issuer 域与证书撤销列表的 issuer 域或证书撤销列表中 issuerAltName 这一扩展的其中一个值是否相同。

注 2：证书撤销列表可能会包含其他撤销信息，例如，关于系统运营人或登记机构证书的信息。

8. 国家签名认证机构国家证书列表结构

如[RFC 5652]中所规定的那样，国家证书列表是作为 ContentInfo 类型的示例来加以实施的。ContentInfo 必须包含如下所述的 SignedData 类型的单一示例。该 ContentInfo 中不包含其他数据类型。所有国家证书列表必须按唯一编码规则格式进行制作，以便保留其所含签名的完整性。

8.1 SignedData 类型

[RFC 5652]中的处理规则适用。

国家证书列表结构的规范使用下列术语表示每个域的存在要求。

m　强制性 — 该域必须存在
r　建议的 — 该域应该存在
x　不使用 — 该域不得存在
o　选择性 — 该域可以存在

表 7　国家证书列表

值		注释
SignedData		
Version	m	值= v3
digestAlgorithms	m	
encapContentInfo	m	
eContentType	m	id-icao-cscaMasterList
eContent	m	一份 cscaMasterList 的编码内容
certificates	m	必须包含国家证书列表签名者证书，且应该包含可用于验证 signerInfos 域中签名的国家签名认证机构证书。
crls	x	
signerInfos	m	建议各国在该域中只提供 1 个 signerinfo。

值		注释
SignerInfo	m	
version	m	该域的值由 sid 域决定。见[RFC 5652]中关于该域的规则。
sid	m	
subjectKeyIdentifier	r	建议支持该域，而非 issuerandSerialNumber。
digestAlgorithm	m	用于得出 encapsulatedContent 和 SignedAttrs 哈希值的算法的算法标识符。 见注 1。
signedAttrs	m	可能包含额外的属性。但是接收国不必处理这些属性，除了为验证签名值之外。 signedAttrs 必须包括签名时间（见[PKCS #9]）。
signatureAlgorithm	m	用于得出签名值的算法的算法标识符，及任何相关参数。 见注 1。
signature	m	签名生成过程的结果。
unsignedAttrs	o	尽管可能包含该域，但是接收国可选择将它忽略。

注 1：DigestAlgorithmIdentifiers 必须省略“零”参数，而对于 SignatureAlgorithmIdentifier（如 RFC 3447 所规定），如果没有参数，则必须包括“零”作为参数，即使在按照 RFC 5754 使用 SHA2 算法时也是如此。具体实施时，必须接受两种条件（参数缺失或有“零”参数）下的 DigestAlgorithmIdentifiers。

8.2 ASN.1 国家证书列表规范

```
CscaMasterList
{ iso-itu-t(2) international-organization(23) icao(136) mrtd(1) security(1) masterlist(2)}

DEFINITIONS IMPLICIT TAGS ::=
BEGIN

IMPORTS

— Imports from RFC 5280 [PROFILE], Appendix A.1
```

```
    Certificate
        FROM PKIX1Explicit88
            { iso(1) identified-organization(3) dod(6)
              internet(1) security(5) mechanisms(5) pkix(7)
               mod(0) pkix1-explicit(18) };
— CSCA Master List

CscaMasterListVersion ::= INTEGER {v0(0)}

CscaMasterList ::= SEQUENCE {
    Version         CscaMasterListVersion,
    certList        SET OF Certificate }

— Object Identifiers
id-icao-cscaMasterList OBJECT IDENTIFIER ::=
                                {id-icao-mrtd-security 2}
id-icao-cscaMasterListSigningKey OBJECT IDENTIFIER ::=
                                {id-icao-mrtd-security 3}
END
```

9. 参考材料（规范性）

FIPS 180-2　FIPS 180-2，联邦信息处理标准出版物（FIPS PUB）180-2，《安全哈希标准》，2002 年 8 月。

FIPS 186-4　FIPS 186-4，联邦信息处理标准出版物（FIPS PUB）186-4，《数字签名标准（DSS）》，2013 年 7 月（替换 2009 年 6 月的 FIPS PUB 186-3）。

ISO 3166-1　ISO/IEC 3166-1: 2006，国家及其地区名称代码 — 第 1 部分：国家代码。

ISO/IEC 15946　ISO/IEC 15946: 2002，信息技术 — 安全技术 — 基于椭圆曲线的加密技术。

RFC 3280　RFC 3280，R. Housley，W. Polk，W. Ford，D. Solo，因特网 X.509 公钥基础设施证书和证书撤销列表（CRL）概要，2002 年 4 月。

RFC 4055　RFC 4055，J. Schaad， B. Kaliski，R. Housley，在因特网 X.509 公钥基础设施证书和证书撤销列表（CRL）概要中使用的 RSA 加密额外算法和标识符，2005 年 6 月。

RFC 5652　RFC 5652，R. Housley，加密电文句法，2009 年 9 月。

RFC 5280　RFC 5280，D. Cooper，S. Santesson，S. Farrell，S. Boeyen，R. Housley，W. Polk，因特网 X.509 公钥基础设施证书和证书撤销列表（CRL）概要，2008 年 5 月。

TR 03111 BSI TR-03111：椭圆曲线加密技术 2.0 版本，2012 年。

X9.62 X9.62，用于金融服务业的公钥加密技术：椭圆曲线数字签名算法（ECDSA），1999 年 1 月 7 日。

X.509 ITU-T X.509 | ISO/IEC 9594-8，2008 年：信息技术 — 开放系统互联 — 目录：公钥和属性证书框架。

X.690 ITU-T X.690 2008：信息技术 — ASN.1 编码规则：基本编码规则（BER）、规范编码规则（CER）和唯一编码规则（DER）规范。

— — — — — — — —

第 12 部分附录 A

有效期（资料性）

下列示例描述了第 4 部分所述的各种情景下私钥使用期限和公钥证书有效期的计算方法。

A.1 示例 1

第一个示例描述了电子机读旅行证件有效期为五年的情景。由于每天都签发大量的电子机读旅行证件，这一政策旨在将私钥使用期限和公钥证书有效期保持在最小值。在本示例中，证件签名者证书的最短私钥使用期限是 1 个月。

项目	使用/有效期
电子机读旅行证件有效性	5 年
证件签名者私钥使用期限	1 个月
证件签名者证书有效期	5 年+1 个月
国家签名认证机构私钥使用期限	3 年
国家签名认证机构证书有效期	8 年+1 个月

本示例的结果是当第一个国家签名认证机构证书失效时，将有至少 36 个已经签发的证件签名者证书（每个证书对应一个使用期限为一个月的私钥）。在第一个国家签名认证机构证书失效前的几个月，将有至少其他两个已经签发的国家签名认证机构证书（每个证书对应一个使用期限为三年的私钥）。

A.2 示例 2

第二个示例描述了电子机读旅行证件有效期为十年的情景。该政策旨在将私钥使用期限和公钥证书有效期保持在平均长度。

项目	使用/有效期
电子机读旅行证件有效期	10 年
证件签名者私钥使用期限	2 个月

项目	使用/有效期
证件签名者证书有效期	10 年+2 个月
国家签名认证机构私钥使用期限	4 年
国家签名认证机构证书有效期	14 年+2 个月

本示例的结果是当第一个国家签名认证机构证书失效时，将有至少 24 个已经签发的证件签名者证书（每个证书对应一个使用期限为两个月的私钥）。在第一个国家签名认证机构证书失效前的几个月，将有至少其他三个已经签发的国家签名认证机构证书（每个证书对应一个使用期限为四年的私钥）。

A.3 示例 3

最后一个示例描述了电子机读旅行证件有效期为十年的情景。该政策旨在使用最长的私钥使用期限和公钥证书有效期。

项目	使用/有效期
电子机读旅行证件有效期	10 年
证件签名者私钥使用期限	3 个月
证件签名者证书有效期	10 年+3 个月
国家签名认证机构私钥使用期限	5 年
国家签名认证机构证书有效期	15 年+3 个月

本示例的结果是当第一个国家签名认证机构证书失效时，将有至少 20 个已经签发的证件签名者证书（每个证书对应一个使用期限为三个月的私钥）。在第一个国家签名认证机构证书失效前的几个月，将有至少其他三个已经签发的国家签名认证机构证书（每个证书对应一个使用期限为五年的私钥）。

— — — — — — — —

第 12 部分附录 B

证书和证书撤销列表概要参考文本
（资料性）

第 7 节所规定的证书和证书撤销列表概要的依据是所参考的文件中规定的定义和基本概要要求。以下表格复制了这些源文件（截至编制本文件之时）一些相关部分的简短摘录。提供这些摘录是为了帮助读者理解电子机读旅行证件证书以及证书撤销列表概要中规定的一些要求的背景。这些摘录并非为了取代参考文件作为参考的依据。在任何情况下，要获取所提到的组成部分/扩展的完整规范以及获取最新规范，必须使用实际的参考文件。

表 8　证书的域和扩展

组成部分/扩展	参考	相关摘录
Certificate	RFC 5280 – 4.1.1	
TBSCertificate	RFC 5280 – 4.1.1.1	
signatureAlgorithm	RFC 5280 – 4.1.1.2	
signatureValue	RFC 5280 – 4.1.1.3	
TBSCertificate	RFC 5280 – 4.1.2	
version	RFC 5280 – 4.1.2.1	当按照本概要的预期使用扩展时，版本必须是 3（值为 2）。
serialNumber	RFC 5280 – 4.1.2.2	序列号必须是认证机构为各证书分配的一个正整数。该序列号对于给定认证机构签发的每个证书来说必须是唯一的（即，签发者名称和序列号能够确定证书的唯一性）。认证机构必须要求 serialNumber 为一个非负整数。 鉴于上文提到的唯一性要求，序列号可以包含长整数。证书使用者必须能够处理长达 20 个八位位组的 serialNumber 值。遵守相关规则的认证机构不得使用长度超过 20 个八位位组的 serialNumber 值。

组成部分/扩展	参考	相关摘录
	X.690 – 8.3.2	如果整数值编码的内容八位位组包括一个以上的八位位组，则第一个八位位组的所有位和第二个八位位组的第 8 位： a) 不应都为 1；和 b) 不应都为零。 注：这些规则确保了在对整数值进行编码时总是使用可能最少的八位位组。
	X.690 – 8.3.3	内容八位位组应为等于整数值的一个二进制补码数值，包括第一个八位位组的第 8 位至第 1 位，后面接着第二个八位位组的第 8 位至第 1 位，再后面依次接着各个八位位组的第 8 位至第 1 位，直至并包括内容八位位组的最后一个八位位组。
signature	RFC 5280 – 4.1.1.2	该域必须包括与序列 Certificate 内的 signatureAlgorithm 域相同的算法标识符。
issuer	RFC 5280 – 附录 A.1	X520countryName ::= PrintableString (SIZE (2)) X520SerialNumber ::= PrintableString (SIZE (1..ub-serial-number))
	RFC 5280 – 4.1.2.4	遵守本概要的认证机构必须使用 DirectoryString 的 PrintableString 编码或者 UTF8String 编码。
	ISO 3166-1	
validity	RFC 5280 – 4.1.2.5	notBefore 和 notAfter 均可编码为 UTCTime 或者 GeneralizedTime。 遵守本概要的认证机构必须总是将直至 2049 年的证书有效期编码为 UTCTime。2050 年或者之后的证书有效期必须编码为 GeneralizedTime。
(if encoded as UTCTime)	X.690 – 11.8.1	按照 ITU-T X.680 | ISO/IEC 8824-1 关于 UTCTime 的条款所述，编码应以“Z”结尾。
	X.690 – 11.8.2	秒元素应始终存在。
(if encoded as GeneralizedTime)	X.690 – 11.7.1	按照 ITU-T Rec. X.680 | ISO/IEC 8824-1 关于 GeneralizedTime 的条款所述，编码应以“Z”结尾。

组成部分/扩展	参考	相关摘录
	X.690 – 11.7.2	秒元素应始终存在。
	RFC 5280 – 4.1.2.5.2	GeneralizedTime 的值不得包括小数秒。 对于本概要，GeneralizedTime 的值必须表述为格林尼治标准时间（Zulu），并且必须包括秒（即，时间是 YYYYMMDDHHMMSSZ），即使秒数为零。
subject	RFC 5280 – 附录 A.1	X520countryName ::= PrintableString (SIZE (2)) X520SerialNumber ::= PrintableString (SIZE (1..ub-serial-number))
	RFC 5280 – 4.1.2.6	遵守本概要的认证机构必须使用 DirectoryString 的 PrintableString 编码或者 UTF8String 编码。
subjectPublicKeyInfo	RFC 5280 – 4.1.2.7	
issuerUniqueID	RFC 5280 – 4.1.2.8	遵守本概要的认证机构不得生成带有唯一标识符的证书。
subjectUniqueID	RFC 5280 – 4.1.2.8	遵守本概要的认证机构不得生成带有唯一标识符的证书。
extensions	X.690 – 11.5	在对 set 值或者 sequence 值进行编码时不应包括对等于其默认值的任何组成部分的值进行编码。
AuthorityKeyIdentifier	RFC 5280 – 4.2.1.1	由遵守相关规则的认证机构生成的所有证书都必须包括 authorityKeyIdentifier 扩展中的 keyIdentifier 域，以促进认证路径的构建。有一个例外情况。如果认证机构分发的是“自签名”证书形式的公钥，则可以省去机构密钥标识符。
keyIdentifier		
authorityCertIssuer		
authorityCertSerialNumber		

组成部分/扩展	参考	相关摘录
SubjectKeyIdentifier	RFC 5280 – 4.2.1.2	为促进认证路径的构建，该扩展必须出现在遵守相关规则的认证机构的所有证书上，即包括 cA 值为 TRUE 的基本限制扩展（第 4.2.1.9 节）在内的所有证书。
subjectKeyIdentifier		
KeyUsage	RFC 5280 – 4.2.1.3	当要限制可用于一次以上操作的密钥时，可采取使用管制。
digitalSignature		当通过数字签名机制使用主体公钥以支持证书签名（第 5 位）或者证书撤销列表签名（第 6 位）之外的安全服务时，digitalSignature 位将被确认。
nonRepudiation		
keyEncipherment		
dataEncipherment		
keyAgreement		
keyCertSign		当使用主体公钥来验证公钥证书的签名时，keyCertSign 位将被确认。
cRLSign		当使用主体公钥来验证证书撤销列表（例如证书撤销列表、增量证书撤销列表或机构撤销列表）上的签名时，cRLSign 位将被确认。该位必须在用于验证证书撤销列表上签名的证书内被确认。
encipherOnly		
decipherOnly		
PrivateKeyUsagePeriod	RFC 3280 – 4.2.1.4	遵守本概要的认证机构不得生成带有私钥使用期限扩展的证书，除非这两个组成部分中至少存在一个，并且扩展是非关键性的。
notBefore		notBefore 和 notAfter 在使用时表示为 GeneralizedTime，并且必须按照第 4.1.2.5.2 节中的规定进行说明和解读。
notAfter		

组成部分/扩展	参考	相关摘录
CertificatePolicies	RFC 5280 – 4.2.1.4	如果该扩展是关键性的，路径认证软件必须能够解读该扩展（包括可选限定符），或者必须拒绝该证书。
PolicyInformation		
policyIdentifier		
policyQualifiers		
PolicyMappings	RFC 5280 – 4.2.1.5	
SubjectAltName	RFC 5280 – 4.2.1.6	
IssuerAltName	RFC 5280 – 4.2.1.7	
SubjectDirectoryAttributes	RFC 5280 – 4.2.1.8	
Basic Constraints	RFC 5280 – 4.2.1.9	基本限制扩展可确定证书主体是否为认证机构以及确定包含该证书的有效认证路径的最大深度。遵守相关规则的认证机构必须将该扩展纳入包含用来验证证书数字签名的公钥的所有认证机构证书，并且必须在这些证书中将该扩展标记为关键性的。
cA		cA 布尔表明经认证的公钥是否属于认证机构。如果 cA 布尔未被确认，则密钥用途扩展中的 keyCertSign 位不得被确认。
PathLenConstraint		
NameConstraints	RFC 5280 – 4.2.1.10	
PolicyConstraints	RFC 5280 – 4.2.1.11	
ExtKeyUsage	RFC 5280 – 4.2.1.12	该扩展表明在密钥用途扩展所示的基本用途之外或作为这些用途的替代，经认证的公钥可用作的一个或多个用途。

组成部分/扩展	参考	相关摘录
CRLDistributionPoints	RFC 5280 – 4.2.1.13	
distributionPoint		
reasons		
cRLIssuer		
InhibitAnyPolicy	RFC 5280 – 4.2.1.14	
FreshestCRL	RFC 5280 – 4.2.1.15	
privateInternetExtensions	RFC 5280 – 4.2.2	
NameChange		
DocumentType		
Netscape Certificate Type		
other private extensions		

表 9　证书撤销列表的域和扩展

组成部分/扩展	参考	有关摘录
CertificateList	RFC 5280 – 5.1.1	
tBSCertList	RFC 5280 – 5.1.1.1	
signatureAlgorithm	RFC 5280 – 5.1.1.2	
signatureValue	RFC 5280 – 5.1.1.3	
	RFC 5280 – 5.1.2	
version	RFC 5280 – 5.1.2.1	该可选域描述了经编码的证书撤销列表的版本。当按照本概要的要求使用扩展时，该域必须存在，并且必须指定版本 2（整数值为 1）。

组成部分/扩展	参考	有关摘录
signature	RFC 5280 – 5.1.2.2	该域必须包括与序列 CertificateList 内的签名域相同的算法标识符。
issuer	RFC 5280 – Appendix A.1	X520countryName ::= PrintableString (SIZE (2)) X520SerialNumber ::= PrintableString (SIZE 1..ub-serial-number))
	RFC 5280 – 5.1.2.3 and 4.1.2.4	遵守本概要的认证机构必须使用 DirectoryString 的 PrintableString 编码或者 UTF8String 编码。
thisUpdate	RFC 5280 – 5.1.2.4	遵守本概要的证书撤销列表签发者必须将直至 2049 年的 thisUpdate 编码为 UTCTime。遵守本概要的证书撤销列表签发者必须将 2050 年或者之后的 thisUpdate 编码为 GeneralizedTime。
(if encoded as UTCTime)	X.690 – 11.8.1	按照 ITU-T X.680 | ISO/IEC 8824-1 关于 UTCTime 的条款所述，编码应以“Z”结尾。
	X.690 – 11.8.2	秒元素应始终存在。
(if encoded as GeneralizedTime)	X.690 – 11.7.1	按照 ITU-T X.680 | ISO/IEC 8824-1 关于 GeneralizedTime 的条款所述，编码应以“Z”结尾。
	X.690 – 11.7.2	秒元素应始终存在。
	RFC 5280 – 4.1.2.5.2	GeneralizedTime 的值不得包括小数秒。 对于本概要，GeneralizedTime 的值必须表述为格林尼治标准时间（Zulu），并且必须包括秒（即，时间是 YYYYMMDDHHMMSSZ），即使秒数为零。
nextUpdate	5.1.2.5	遵守本概要的证书撤销列表签发者必须将直至 2049 年的 nextUpdate 编码为 UTCTime。遵守本概要的证书撤销列表签发者必须将 2050 年或者之后的 nextUpdate 编码为 GeneralizedTime。
(if encoded at UTCTime)	X.690 – 11.8.1	按照 ITU-T X.680 | ISO/IEC 8824-1 关于 UTCTime 的条款所述，编码应以“Z”结尾。
	X.690 – 11.8.2	秒元素应始终存在。

组成部分/扩展	参考	有关摘录
(if encoded at GeneralizedTime)	X.690 – 11.7.1	按照 ITU-T X.680 | ISO/IEC 8824-1 关于 GeneralizedTime 的条款所述，编码应以“Z”结尾。
	X.690 – 11.7.2	秒元素应始终存在。
	RFC 5280 – 4.1.2.5.2	GeneralizedTime 的值不得包括小数秒。 对于本概要，GeneralizedTime 的值必须表述为格林尼治标准时间（Zulu），并且必须包括秒（即，时间是 YYYYMMDDHHMMSSZ），即使秒数为零。
revokedCertificates	RFC 5280 – 5.1.2.6	如果没有已撤销的证书，则不得有撤销证书列表。否则，要根据序列号列出已撤销的证书。
crlExtensions	RFC 5280 – 5.2	遵守相关规则的证书撤销列表签发者需要在签发的所有证书撤销列表内包含机构密钥标识符（第 5.2.1 节）以及证书撤销列表号码（第 5.2.3 节）扩展。
	X.690 – 11.5	在对 set 值或者 sequence 值进行编码时不应包括对等于其默认值的任何组成部分的值进行编码。
authorityKeyIdentifier	RFC 5280 – 5.2.1	遵守相关规则的证书撤销列表签发者必须使用密钥标识符方法，并且必须在签发的所有证书撤销列表内包含该扩展。
issuerAlternativeName	RFC 5280 – 5.2.2	
cRLNumber	RFC 5280 – 5.2.3	遵守本概要的证书撤销列表签发者必须在所有的证书撤销列表内包含该扩展，并且必须将该扩展标记为非关键性的。 CRLNumber ::= INTEGER (0..MAX) 鉴于上述要求，证书撤销列表号码可以包含长整数。证书撤销列表核验者必须能够处理长达 20 个八位位组的 CRLNumber 值。遵守相关规则的证书撤销列表签发者不得使用长度超过 20 个八位位组的 CRLNumber 值。
	X.690 – 8.3.2	如果整数值编码的内容八位位组包括一个以上的八位位组，则第一个八位位组的所有位和第二个八位位组的第 8 位： a) 不应都为 1；和

组成部分/扩展	参考	有关摘录
		b) 不应都为零。 注：这些规则确保了在对整数值进行编码时总是使用可能最少的八位位组。
	X.690 – 8.3.3	内容八位位组应为等于整数值的一个二进制补码数值，包括第一个八位位组的第 8 位至第 1 位，后面接着第二个八位位组的第 8 位至第 1 位，再后面依次接着各个八位位组的第 8 位至第 1 位，直至并包括内容八位位组的最后一个八位位组。
deltaCRLIndicator	RFC 5280 – 5.2.4	
issuingDistribution Point	RFC 5280 – 5.2.5	
freshestCRL	RFC 5280 – 5.2.6	
reasonCode	RFC 5280 – 5.3.1	
holdInstructionCode	RFC 5280 – 5.3.2	
invalidityDate	RFC 5280 – 5.3.3	
certificateIssuer	RFC 5280 – 5.3.4	

— — — — — — — —

第 12 部分附录 C

较早的证书概要
（资料性）

本附录中的证书概要为国际民航组织 Doc 9303 号文件第六版中所规定的。尽管国家签名认证机构必须签发符合第 7 节所述最新概要的证书，但在此处提供了较早的概要，这些概要仅作参考之用，原因是按照较早概要签发的证件将在数年内保持流通，并由查验系统进行处理。

表 10　证书主体

证书组成部分	RFC 3280 中的章节	国家签名认证机构证书	证件签名者证书	注释
Certificate	4.1.1	m	m	
TBSCertificate	4.1.1.1	m	m	见本表的下一部分
SignatureAlgorithm	4.1.1.2	m	m	这里插入的值取决于所选择的算法
SignatureValue	4.1.1.3	m	m	这里插入的值取决于所选择的算法
TBSCertificate	4.1.2			
version	4.1.2.1	m	m	应为 v3
serialNumber	4.1.2.2	m	m	
signature	4.1.2.3	m	m	这里插入的值应与 signatureAlgorithm 的对象标识符相匹配
issuer	4.1.2.4	m	m	见 A1.5
validity	4.1.2.5	m	m	实施时应指明 2049 年之前使用世界协调时间，2049 年之后使用 GeneralizedTime
subject	4.1.2.6	m	m	见 A1.5
subjectPublicKey Info	4.1.2.7	m	m	

证书组成部分	RFC 3280 中的章节	国家签名认证机构证书	证件签名者证书	注释
issuerUniqueID	4.1.2.8	x	x	
subjectUniqueID	4.1.2.8	x	x	
extensions	4.1.2.9	m	m	见关于应该存在哪些扩展的下表

表 11 扩展

扩展名称	RFC 3280 中的段落	国家签名认证机构证书	证件签名者证书	注释
AuthorityKeyIdentifier	4.2.1.1	o	m	所有证书都必需具备，自签名的国家签名认证机构证书除外
SubjectKeyIdentifier	4.2.1.2	m	o	
KeyUsage	4.2.1.3	mc	mc	应将该扩展标记为关键性的
PrivateKeyUsagePeriod	4.2.1.4	o	o	这将是私钥的签发周期
CertificatePolicies	4.2.1.5	o	o	
PolicyMappings	4.2.1.6	x	x	
SubjectAltName	4.2.1.7	x	x	
IssuerAltName	4.2.1.8	x	x	
SubjectDirectoryAttributes	4.2.1.9	x	x	
BasicConstraints	4.2.1.10	mc	x	应将该扩展标记为关键性的
NameConstraints	4.2.1.11	x	x	
PolicyConstraints	4.2.1.12	x	x	
ExtKeyUsage	4.2.1.13	x	x	

扩展名称	**RFC 3280** 中的段落	国家签名认证机构证书	证件签名者证书	注释
CRLDistributionPoints	4.2.1.14	o	o	如果签发国或签发机构选择使用该扩展，则应将国际民航组织公钥目录包含在内，作为一种分发点。在实施时还可出于本地目的，包含相关的证书撤销列表分发点；其他接收国可对其予以忽略。
InhibitAnyPolicy	4.2.1.15	x	x	
FreshestCRL	4.2.1.16	x	x	
privateInternetExtensions	4.2.2	x	x	
other private extensions	不适用	o	o	如果出于本国目的，包含任何专用扩展，则不应对其进行标记。不主张签发国或签发机构包含任何专用扩展。
AuthorityKeyIdentifier	4.2.1.1			
keyIdentifier		m	m	如果使用该扩展，应支持该域采取最小的值
authorityCertIssuer		o	o	见 A1.5
authorityCertSerialNumber		o	o	
SubjectKeyIdentifier	4.2.1.2			
subjectKeyIdentifier		m	m	
KeyUsage	4.2.1.3			
digitalSignature		x	m	
nonRepudiation		x	x	
keyEncipherment		x	x	
dataEncipherment		x	x	

扩展名称	RFC 3280 中的段落	国家签名认证机构证书	证件签名者证书	注释
keyAgreement		x	x	
keyCertSign		m	x	
cRLSign		m	x	
encipherOnly		x	x	
decipherOnly		x	x	
BasicConstraints	4.2.1.10			
cA		m	x	对于认证机构证书，该扩展为 TRUE
PathLenConstraint		m	x	对于新的国家签名认证机构证书，该扩展为 0；对于国家签名认证机构链接证书，该扩展为 1
CRLDistributionPoints	4.2.1.14			
distributionPoint		m	x	
reasons		m	x	
cRLIssuer		m	x	
CertificatePolicies	4.2.1.5			
PolicyInformation				
policyIdentifier		m	m	
policyQualifiers		o	o	

— — — — — — — —

第 12 部分附录 D

RFC 5280 验证的兼容性
（资料性）

本附录为想要使用采用[RFC 5280]认证路径和证书撤销列表验证算法的系统的接收国提供了指导。

电子机读旅行证件公钥基础设施信任模型是[RFC 5280]中所规定的验证程序所涵盖的模型的一个部分。第 D.1 节确定了[RFC 5280]所规定步骤中为电子机读旅行证件应用所必需的部分，并提供了认证路径验证、证书撤销列表验证和撤销检查所需要的输入值和初始化值以及过程。

第 D.2 节涵盖了[RFC 52180]中所规定的与电子机读旅行证件应用无关的其余步骤。提供了认证路径验证和证书撤销列表验证的输入值和初始化值。本节中的指导用于相关工具采用的是完整的[RFC 5280]算法而不仅仅是 D.1 中所述的子集的情况。

第 D.3 节为支持在国家签名认证机构改名之后将基于[RFC 5280]的证书撤销列表处理工作加以扩展以涵盖撤销检查提供了指导。

D.1 与电子机读旅行证件相关的步骤

此处规定的电子机读旅行证件认证路径验证程序是以[RFC 5280]中所述的程序为依据的。使用了相同的术语和过程说明。电子机读旅行证件证书概要将认证路径限制为一个单一的证书，并禁止使用其他应用中使用的很多可选特征，例如[RFC 5280]中规定的互联网公钥基础设施。电子机读旅行证件认证路径验证程序省去了与这些特征相关的路径验证步骤。

D.1.1 认证路径验证程序

D.1.1.1 输入

[RFC 5280]规定了路径验证算法的一组（共九项）输入值。仅下列三项与电子机读旅行证件应用相关：

- 认证路径：一个单一的证书（例如，证件签名者证书）；
- 当前日期/时间；和
- 信任锚信息，包括：
    - o 可信的签发者名称：如果信任锚采取的是国家签名认证机构证书的形式，则可信的签发者名称是该证书 subject 域的值；

- 可信的公钥算法：如果信任锚采取的是国家签名认证机构证书的形式，则可信的公钥算法取自该证书的 SubjectPublicKeyInfo 域；
- 可信的公钥：如果信任锚采取的是国家签名认证机构证书的形式，则可信的公钥取自该证书的 SubjectPublicKeyInfo 域；和
- 可信的公钥参数：这是一个选择性输入值，只有在可信的公钥算法需要参数时才将其包括在内。如果信任锚采取的是国家签名认证机构证书的形式，则这些参数取自该证书的 SubjectPublicKeyInfo 域。

如果在实施时需要提供另外六个输入值，D.2 提供了这方面的建议。

对于签发正在接受验证的证书的国家签名认证机构，可能存在多个信任锚。在这些信任锚中，必须使用所包含的公钥与正在接受验证的证书中的机构密钥标识符扩展值相匹配的那个信任锚。

D.1.1.2 初始化

[RFC 5280]中规定了 11 个国家变量。仅下列五个与电子机读旅行证件应用相关：

- 应用：max_path_length：初始化为“0”；
- working_issuer_name：初始化为可信的签发者名称的值；
- working_public_key_algorithm：初始化为可信的公钥算法的值；
- working_public_key：初始化为可信的公钥的值；和
- working_public_key_parameters：初始化为可信的公钥参数的值。

如果在实施时需要初始化另外六个变量，D.2 提供了这方面的建议。

D.1.1.3 证书处理

电子机读旅行证件证书的处理步骤是[RFC 5280]中所规定的步骤的一部分。使用这一简化过程处理电子机读旅行证件证书的结果将与使用完整的 RFC 5280 算法的结果一致。如果按 D.2 所述设置了其他输入值和国家变量：

a) 核实基本证书信息。证书必须满足下列各项：
   - 可通过 working_public_key_algorithm、working_public_key 和 working_public_key_parameters 核实证书上的签名；
   - 证书有效期包括当前时间；
   - 在当前时间，证书没有被撤销（详细介绍见 6.3）；和
   - 证书签发者名称是 working_issuer_name。

b) 将证书的 subjectPublicKey 赋给 working_public_key。

c) 如果证书的 subjectPublicKeyInfo 域包含一个参数为非空的算法域，将参数赋给 working_public_key_parameters 变量。如果证书的 subjectPublicKeyInfo 域包含一个参数为空或省去参数的算法域，将证书的 subjectPublicKey 算法与 working_public_key_algorithm 作比较。如果证书的 subjectPublicKey 算法与 working_public_key_algorithm 不同，则将 working_public_key_parameters 设为空值。

d) 将证书的 subjectPublicKey 算法赋给 working_public_key_algorithm 变量。

e) 查明并处理证书中存在的任何其他关键扩展。

f) 处理证书中存在的其他任何经查明的非关键性扩展。

如果步骤 a) 中的任一检查失败或者证书中有任何未被查明从而未能被处理的关键性扩展，路径验证程序失败。否则该程序成功。

D.1.1.4　输出

如果路径验证成功，程序终止，返回成功指示以及 working_public_key、working_public_key_algorithm 和 working_public_key_parameters。

如果路径验证失败，程序终止，返回失败指示和相关原因。

D.1.2　证书撤销列表验证和撤销检查

[REC 5280]中的证书撤销列表验证算法涵盖了各种类型的证书撤销列表，包括增量证书撤销列表、分组证书撤销列表、间接证书撤销列表等等。电子机读旅行证件应用中的证书撤销列表概要极具限制性，禁止使用这些特征。同样还禁止使用 issuingDistributionPoint 扩展以及所有标准化的证书撤销列表记录扩展。因此，电子机读旅行证件应用的证书撤销列表验证和撤销检查相对简单。

D.1.2.1　输入

[RFC 5280]规定了证书撤销列表验证算法的两个输入值。仅下列一个与电子机读旅行证件应用相关。如果在实施时需要提供另外一个输入值，D.2 提供了这方面的建议。

- 证书：证书序列号和签发者名称

D.1.2.2　初始化

[RFC 5280]中规定了三个国家变量。仅下列一个与电子机读旅行证件应用相关。如果在实施时需要初始化另外两个变量，D.2 提供了这方面的建议。

- cert_status：初始化为值 UNREVOKED。

D.1.2.3 证书撤销列表处理

电子机读旅行证件应用中的所有证书撤销列表都是完整的证书撤销列表，涵盖由签发证书撤销列表的国家签名认证机构所签发的所有当前证书。无分组、增量或间接证书撤销列表。电子机读旅行证件应用的证书撤销列表处理算法步骤为：

a) 获取签发证书的国家签名认证机构的当前证书撤销列表。如果不能获取证书撤销列表，则将 cert_status 变量设为 UNDETERMINED，并停止处理。

b) 核实证书撤销列表签发者与签发所涉证书的国家签名认证机构为同一实体。因为每一国家仅有一个国家签名认证机构，并且电子机读旅行证件应用是封闭性的，由查验系统保存该应用所特有的证书撤销列表缓存，所以，核实证书撤销列表的签发者域中的国家名称与证书签发者域中的国家名称是相同的就足够了。

   - 如果自签发证书后，国家签名认证机构并未更改名称，那么，证书撤销列表中的签发者域和证书中的签发者域将是相同的。
   - 如果自签发证书后，国家签名认证机构更改了名称，那么，证书签发者域名称和证书撤销列表签发者域中的国家属性将是相同的，但其他一些属性可能不同。
   - 如果信赖方希望核实并未对一些非电子机读旅行证件证书撤销列表进行过替换，信赖方可以选择性地核实其拥有关于国家签名认证机构两个名称的信任锚并且这些信任锚是针对同一国家签名认证机构的。如果国家签名认证机构更改了名称，并且将可选的 issuerAltName 扩展放入了证书撤销列表中，则信赖方可以选择性地核实证书中的签发者域与该扩展的其中一个值是相同的。

如果证书撤销列表签发者并非签发证书的国家签名认证机构，则将 cert_status 变量设为 UNDETERMINED，并停止处理。

c) 验证证书撤销列表签发者的认证路径。注意在电子机读旅行证件应用中，所有证书撤销列表都是由作为针对各自路径的信任锚的国家签名认证机构签发的。与[RFC 5280]中的算法不同，电子机读旅行证件应用不要求用来验证证书撤销列表认证路径的信任锚与用来验证目标证书的信任锚为同一个。但是，如果信任锚不同，它们必须都是针对同一国家签名认证机构的信任锚。与[RFC 5280]不同，在电子机读旅行证件应用中，一个既定的国家签名认证机构有多个同时有效的信任锚。如果不能成功验证认证路径，则将 cert_status 变量设为 UNDETERMINED，并停止处理。

d) 核实证书撤销列表上的签名。如果不能成功核实该签名，则将 cert_status 变量设为 UNDETERMINED，并停止处理。

e) 搜索证书撤销列表上的证书。如果发现与证书签发者和序列号相匹配的某条记录，则将 cert_status 变量设为 UNSPECIFIED。

D.1.2.4　输出

返回 cert_status。如果步骤 a)、b)、c)或 d)失败，状态将为 UNDETERMINED。如果证书在证书撤销列表中被列为已撤销，则状态为 UNSPECIFIED。如果证书撤销列表验证成功，但证书未列在证书撤销列表上，则状态为 UNREVOKED。

D.2　电子机读旅行证件不需要采取的步骤

D.2.1　认证路径验证

与电子机读旅行证件验证不相关的其他输入值的设定包括：

- initial-policy-mapping-inhibit：设定为禁止策略映射；
- initial-any-policy-inhibit：设定为禁止处理 any-policy 值；
- initial-permitted-subtrees：设定为允许所有子树；
- initial-excluded-subtrees：设定为不排除子树；
- initial-explicit-policy：不应设定；和
- user-initial-policy-set：设定为特殊值“any-policy”。

与电子机读旅行证件不相关的国家变量的初始化包括：

- permitted_subtrees：初始化为允许所有子树；
- excluded_subtrees：初始化为不排除子树；
- inhibit_any_policy：如果设定了 initial-any-policy-inhibit，则初始化为“0”。否则，将其设定为 1 或者大于 1 的任何值；
- policy_mapping：初始化为“0”；
- explicit_policy：初始化为“2”；和
- valid_policy_tree：将 valid_policy 元素初始化为“anyPolicy”，将 qualifier_set 元素初始化为空，以及将 expected_policy_set 初始化为“anyPolicy”。

D.2.2 证书撤销列表验证

与电子机读旅行证件验证不相关的其他输入值的设定包括：

- use-deltas：设定为禁止使用增量。

与电子机读旅行证件应用不相关的国家变量的初始化包括：

- reasons_mask：初始化为空集；和
- Interim_reasons_mask：初始化为特殊值“all-reasons”。

D.3 为处理证书撤销列表需要做出的改动

按照[RFC 5280]中的证书撤销列表验证程序运行的证书撤销列表验证系统并不支持认证机构进行过更名的环境，如电子机读旅行证件应用环境。因此，需对这些系统做一些改动，以应对这一特殊情况，具体如下所述：

a) 在[RFC 5280]证书撤销列表验证程序第 6.3.3 条的步骤 a) 中，使用所涉证书的证书撤销列表分发点扩展分发点域的名称来更新相关证书撤销列表的本地缓存。对于电子机读旅行证件应用，需要对这一步骤进行修改，仅应使用分布点域的 countryName 属性来确定和获取相关的证书撤销列表。

b) 在[RFC 5280]证书撤销列表验证程序第 6.3.3 条的步骤 f）中，要求使用与用于验证目标证书相同的信任锚来验证证书撤销列表签发者的认证路径。对于电子机读旅行证件应用来说无此要求，因为国家签名认证机构的每个公钥都设有独立的信任锚。

用于验证证书撤销列表签发者的信任锚将为用来签署证书撤销列表的私钥所对应的国家签名认证机构公钥的信任锚。用来验证目标证书认证路径的信任锚可能是国家签名认证机构较早的一个密钥对的信任锚。

— 完 —

ISBN 978-92-9249-964-8

